

AdvocateAuroraHealth

Title: AAH HIT Cloud Design Standard		Document Number:
Document Type: ☐ Policy ☐ Procedure ☐ Guideline ☒ Other Standard		Last Review/Revision Date:
Content Applies to Patient Care: (Select all that apply) ☐ Adults ☐ Pediatrics (Under 18)	Content Applies to: (Select One) ☐ Clinical ☒ Administrative	Next Review Date:
		Effective Date:
Scope: ☐ AAH System ☐ ACH ☐ AAH IL Only ☐ AAH WI Only ☐ Site Only (Location Name): ☒ Department Only (Department Name): HIT		

I. PURPOSE

This standard is to establish a framework of principles and guidance that will ensure the effective and efficient management of AAH's Cloud Design strategy consistent with the mission and goals of AAH. The hosted service model category chosen will determine which components are within AAH's direct control, but these general provisions should be considered as part of the overall design and implementation.

II. SCOPE

The following are in scope for Advocate Aurora Health (AAH)'s HIT team members who management and implement cloud solution deployments:

- Deployment model: Public cloud, including deployment service models from Software as a Service (SaaS), Platform as a Service (PaaS), and Infrastructure as a Service (IaaS)

III. DEFINITIONS/ABBREVIATIONS

Authentication Method: This is AAH's Enterprise Active Directory.

- This is Dirsrvcs.org using LDAPS
- Azure Active Directory

Azure Blob: For very large objects which is typically unstructured data.

Examples include storing text, images and videos. Offers three tiers of storage:

- Hot – data to be accessed consistently
- Cool – data to be accessed occasionally
- Archive – data that is rarely if ever accessed

Azure Disk: Provides disks for virtual machines, applications and other services.

Azure Files: Allows the creation of a shared drive which can be accessed through SMB.

Azure Table: Scalable, ability to store large amount of data. Ideal storage for semi-structured .data.

Azure Queues: FIFO architecture for storing messages that do not need to be in a certain order. Allows high volumes of messages, process them asynchronously and consume them when needed.

Azure Region: A geographical area containing at least one, but potentially multiple datacenters that are networked together

Azure Availability Set: Ensures that virtual machines are deployed are distributed across multiple isolated hardware nodes within a cluster

Azure Availability Zone: Ensures that virtual machines and data are protected from data center failures by enabling distribution of VMs across multiple physical locations within a region

Azure Site Recovery: Site Recovery is a native disaster recovery as a service (DRaaS). It provides replication of VMs to another Azure region for regional disaster recovery and business continuity. Azure Site Recovery is used to recover apps in the event of source region outages, or to conduct periodic disaster recovery drills to ensure compliance requirements are met.

Cloud Access Security Broker (CASB): A cloud-hosted software or on-premises software or hardware that act as an intermediary between users and cloud service providers. The ability of a CASB to address gaps in security extends across SaaS, PaaS, and IaaS environments. An example is Proofpoint.

Disaster Recovery (DR) Site: a physical location separated from the cloud vendor's primary location. Its purpose is to keep the cloud services and systems running in the event of a power outage, cyberattack, network failure, natural disaster, unexpected downtime, sabotage or other event that takes down the primary location. This DR site is used to recover apps in the event of source region outages, or to conduct periodic disaster recovery drills to ensure compliance requirements.

Enterprise Monitoring (EME): Enterprise Monitoring team

High Availability: High Availability is a characteristic of a system which aims to ensure an agreed level of operational performance, usually uptime, for a higher-than-normal period.

Infrastructure as code (IaC): Managing and provisioning infrastructure through definition files instead of through a manual point and click process.

Infrastructure as a Service (IaaS): Allows for ability to configure and manage the hardware for your application and is most flexible cloud service.

Input output operations per second: IOPS

Legacy Active Directory: This is any source domain such as:

- core.acllab.net, ahc.root.loc, ahc-ad.advocatehealth.com, dryer-wa domains.

This is for systems going into the source domain because they cannot meet the Tier 1 requirements. Also using LDAPS

Planned Outage: A phase that results when a solution is intentionally not available for team member use at a pre-selected time, usually for the purpose of preventive maintenance or upgrade.

Platform as a Service (PaaS): The platform management is handled by the cloud provider and the focus is on the application development.

Public cloud. The cloud infrastructure is provisioned for use by AAH. It may be owned, managed, and operated by a business, academic, or government organization, or some combination of them. It exists on the premises of the cloud provider.

Public IP address: Required if the solution needs to be accessed directly through the Internet.

Service Level Agreement: SLA

Software as a Service: Users pay for the software as they use it on a subscription model; a pay-as-you-go pricing model.

Unplanned Outage: Phase of a solution when it is not available for team member use and the outage was not planned.

Vendor Based Authentication:

- Domain one-way trust
- SSO Single Sign On
- SAML Security Assertion Markup Language
- Azure Application

Version Control System (VCS): A system used for storing files and tracking changes to code over time.

Virtual Machine Series:

A-Series – Entry-level virtual machines. Example workloads include:

- Development, test and POC servers
- Low traffic web servers
- Small to medium databases

D-Series – General purpose virtual machines. Example workloads include:

- Enterprise applications
- Relational databases

N-Series – GPU enabled virtual machines. Example workloads include:

- Simulation workloads
- Deep learning

IV. STANDARDS

A. Cloud Administration Control Subscriptions

1. All workloads will be assigned to of the standard AAH subscription. If custom subscriptions builds are needed, it will be determined based on contracting needs determined between AAH and the vendor.
2. For implementation, there will be 4 AAH standard subscription :
 - a) Production
 - b) Development
 - c) Test
 - d) Security
3. Cloud Control subscription will span two regions:
 - a) East US 2 (primary)
 - b) Central US (secondary)
4. The Security subscriptions serve as the ingress point for all other environments in Azure to on premises.

B. Identity and Access Management Design

1. Enforce multi-factor authentication for users with administrative rights to the Azure environment
2. Integrate Azure AD logs into the organizations log aggregator
 - a) Will log to a SIEM solution for Cloud Logging
3. Follow a least-privileged approach to operational access by utilizing:
 - a) Azure Active Directory (Azure AD)
 - b) Azure role-based access control (Azure RBAC)
4. Will utilize platform provided rolesUsers are to be added to roles which are assigned to resources
 - a) Users are not to be added to resources directly
5. Leverage Azure Active Directory (AAD) for all identity (users) needs in the cloud; use traditional Active Directory (AD) for managing IaaS resources (computers) in the cloud

6. The current AD domain will be extended to the cloud, but Domain Controllers (DCs) will not be deployed in Azure – i.e. IaaS resources must traverse the ER circuit to authenticate to and get authorization from an on-premises DC
7. Domain Admins must NOT be subscription admins

C. Compute Design

1. Utilization of blueprints to ensure consistency in deployment
2. Design policies to limit the types of resources users can provision
3. IaaS virtual machines will require selecting the best sizing specification, based on the following criteria:
 - a) CPU core count
 - b) Maximum memory
 - c) Disk IOPS capacity
 - d) Number of mountable drives
 - e) Number of network interfaces
4. Server Operating System:
 - a) Linux: RedHat Enterprise Linux 7 or above

D. Network Design

Some of the general provisions that should be considered include, but are not limited to:

1. The following should be determined, documented, and allocated for the hosted environment taking into consideration potential growth.
 - a. An IP addressing scheme
 - b. Traffic routing needs and processes
 - c. A DNS (name resolution) scheme
 - d. Any load balancing needs
2. Private, dedicated circuitry will be used whenever possible when connecting to the AAH private network to the hosted environment.
 - a. ExpressRoute should be used with Azure-hosted installations. Exceptions to this must be approved via AAH's Exceptions process.
 - b. Multiple peering points between the AAH and the hosted environment should be used, whenever possible (redundant, diverse connectivity, geographically dispersed).
3. Application traffic should be categorized, tagged, and placed into an appropriate QoS class, with voice traffic being placed into Real Time (EF/DSCP 46) class. Network devices and services should be configured to act appropriately on these QoS markings whenever possible.

E. Network Security Design

1. Implementation and utilization of CASB
 - a) Proofpoint is AAH's current CASB tool

F. **Storage Design**

1. Storage accounts have public endpoints, so it must be protected using a combination of access controls, least privilege assignment, access delegation, storage monitoring, and encryption
2. There will be multiple storage accounts, a minimum of two (2):
 - a) Encrypted workloads
 - b) Standard workloads
3. All data of a sensitive nature must be encrypted:
 - a) Azure Disk Encryption – used to encrypt data at the volume level using Windows BitLocker technology
 - b) Azure Storage Service Encryption – used to encrypt data as it is being written to the storage blob or to file storage
 - c) Transparent Data Encryption – used to encrypt data for SQL databases
4. The logical D:\ drive will be re-assigned to another logical drive (still to be determined), as needed
5. Storage replication will be leveraged for data durability, as needed:
 - a) Locally-Redundant Storage (LRS) – use for all general-purpose virtual machines and non-critical data ^[1]_{SEP}
 - b) Zone-Redundant Storage (ZRS) or Geo-Redundant Storage (GZRS) – used for critical data
6. Read-access Geo-Redundant Storage (GRS) – use for critical data that does not require write transactions
7. Storage Analytics is enabled by default for any new storage account – existing accounts may need to have this feature manually enabled

G. **Monitoring Design**

1. Accounts will be provided for the Enterprise Monitoring (EME) team to access any cloud service's internal metrics monitoring interface and configuration panel.
2. Access will be granted for API-level integration with the enterprise standard monitoring platforms. Additional access to hardware, software and OS-level metrics will be provided where exposed by the solution provider. If remote polling of these components is not allowed or available, a locally installed collector or "agent" may be employed to gather data.
3. The EME team will offer the following levels of service for all cloud-based applications and services:
 - a) Base Monitoring (default to all, where available)
 - (a) Availability
 - (b) Basic response time for resource
 - b) Resource Utilization

- (a) Performance
 - (b) Capacity
 - c) Billing Insights
- b) Advanced Monitoring (by request, where available)
 - a) Application Service
 - b) End-User experience
 - (a) Synthetic (Robotic) Transactions
- 4. Cloud service health and availability data will be available to the teams responsible for managing the service, as well as those who's services rely upon these systems. Similarly, this data will be made available to the enterprise's Operations group(s) for alert management and ticketing workflow. Access restriction for data considered sensitive will be considered after a design review with the primary stakeholders and appropriate leadership teams.
- 5. Alert Management will be handled by the primary stakeholders in concert with Datacenter Operations. Notification and ticketing will be configured by the EME team using mechanisms native to the enterprise monitoring platform as well as integrations with ServiceNow.

H. **High Availability Design**

- 1. High Availability is designed based on the application availability requirements, criticality, and SLA between AAH HIT and the consuming business unit to ensure that the application can withstand all planned and unplanned outages and to provide continuous processing for.

I. **Data Backup**

- 1. Refer to HIT Data Backup & Recovery policy and Data Backup Retention standard.

J. **Disaster Recovery**

- 1. Applications/solutions should be architected to adhere to placement within the HIT Disaster Recovery Tiers Standard.

K. **Virtual Machines Hosting**

Below is some information which is meant to help assess where virtual servers should be placed within AAH when planning the virtual machine hosting location and its appropriate domain environment.

- 1. IaaS –VMs solutions will be placed inside AAH Azure tenant
- 2. PaaS - Solutions will be placed inside AAH Azure tenant
- 3. SaaS – will be vendor dependent based upon the Risk Review, BAA (as applicable), and Contracting
 - a) Needs to be hosted within the United States

L. **Automation Design**

1. A dedicated cloud-based service account will be required to access cloud provider APIs and endpoints.
2. The lifecycle management and provisioning of virtual machines (VMs) and other cloud resources will be provided through vRealize Automation tools..
3. Cloud templates for provisioning will be designed based on use case and standards outlined from other stakeholders (networking, storage, security, authentication). The source code for templates will be stored in an AAH version control system.

M. Databases - SQL

Deploying SQL depends on how many databases there will be, if an Agent (scheduler) is required, or if operating system access is needed.

These PaaS options are preferred because these include automated backups, updates, and disaster recovery.

1. Azure SQL Database: Single self-contained database deployments that do not need an agent.
2. Azure SQL Managed Instance: Multi-database deployments, or those that need instance-level features like the Agent (scheduler)
3. Amazon Relational Database Service: Multi-database deployments (Note: does not appear to have an Agent/Scheduler)
4. If an IaaS (i.e. VM) is needed because access to the operating system is required, then note that AAH is responsible installation, updates, backups, and recoverability this installing.

N. Endpoint Management and Virtualization

1. Endpoint Management: Platforms designed to configure, track, manage and report on the computers used by team members. These computers include desktops, laptops, tablets, and mobile phones.
 - a. Platform(s) to provide real-time endpoint analytics and automated remediations to improve team member experience.
 - b. MDM (mobile device management) platform to manage mobile devices (mobile phones and tablets – IOS/Android). Delivery of applications to mobile devices. Management and configuration of mobile devices.
 - c. Cloud gateway platform(s) to allow communications to desktop(s) operating system that exists in remote locations. Provide seamless device authentication, connectivity, and transfer of operating system data/configuration.
2. Virtualized Desktops: Providing end users a desktop operating system via a virtualized platform.
 - a. Authentication for virtual desktops via cloud-based security
 - b. Desktop applications determined by employee role (referred to as use case)
 - c. Physical device agnostic

V. ROLES AND RESPONSIBILITIES

n/a

VI. CROSS REFERENCES

Health Informatics and Technology Disaster Recovery Planning
HIT Data Backup and Recovery Policy and Standard
Disaster Recovery Tiers Standard
Electronic Systems Account Management (ESAM)

VII. RESOURCES AND REFERENCES

- A. VM Server Placement Guide (v1) (upon request)
- B. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.500-291r2.pdf> . Accessed 04262021. (Standards, July)
- C. Center for Internet Security Controls (v.8):
 - CIS Control 1: Inventory and Control of Enterprise Assets
 - CIS Control 3: Data Protection
 - CIS Control 4: Secure Configuration of Enterprise Assets and Software
 - CIS Control 5: Account Management
 - CIS Control 8: Audit Log Management
 - CIS Control 10:Malware Defenses
 - CIS Control 11: Data Recovery
 - CIS Control 13: Network Monitoring and Defense

VIII. ATTACHMENTS

n/a